

INFOASSURE LIMITED

Capstone Engagement

PayNova Financial Services Ltd

Cybersecurity Assessment: Executive Briefing

Where we stand, what needs to happen next

Prepared for: PayNova Executive Panel

Prepared by: Team Vanguard Infoassure

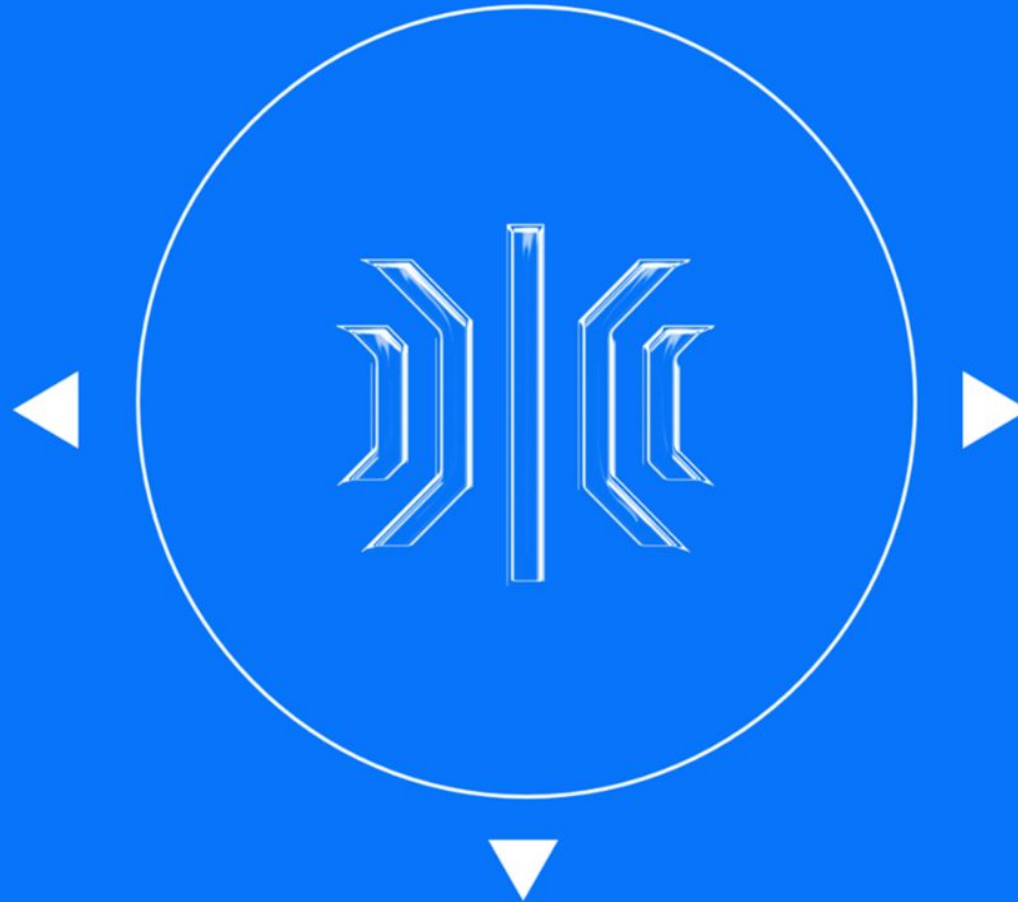
Date: 28 September 2026

Classification: Confidential

Infoassure Corporate Philosophy

Our Vision

To be the most respected
Information Technology
Assurance and GRC firm
of African Origin



Our Mission

To Secure organisations'
assets using best
practice standards and
frameworks.

Our Core Values

RITE: Reliability . Integrity . Tenacity . Efficiency

Where we stand today

23

confirmed findings

across network, AD, web, API and database

4

need immediate action

customer data, card system, admin bypass, DB

5

controls already working

segmentation, secure messaging, LDAP auth

The bottom line

The environment has serious exposures, but every one of them is fixable. There is a clear path from where we are to a defensible position — starting with a small number of actions in the next seven days.

What we tested and what we produced

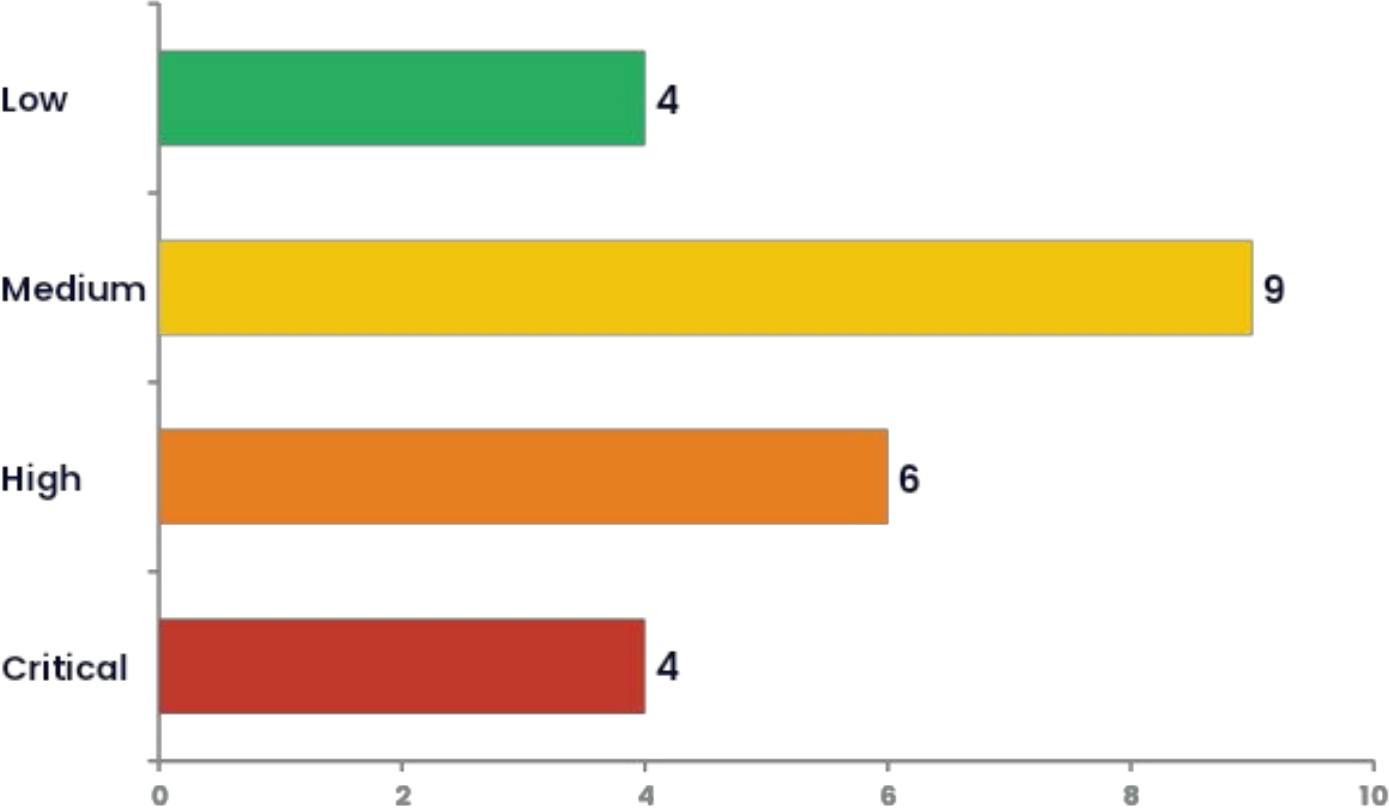
Six areas assessed

- Network exposure and traffic separation
- Active Directory and staff login security
- Customer web application
- Payment card scheme integration
- Customer database security
- Data protection and privacy posture

Four documents produced

- 1 Cybersecurity Assessment Report**
The technical findings and evidence
- 2 Risk Register**
40 tracked risks with owners and deadlines
- 3 Privacy Impact Assessment**
How we meet NDPA, GDPR and UK GDPR
- 4 Incident Response Plan**
What to do when something goes wrong

Findings at a glance



What this tells us

Four showstoppers

Customer data downloadable. Card system open. Admin login bypass. Database root reachable with full privileges.

Concentrated risk

Most Critical / High findings sit in the customer-facing app, the payment API, and the customer database.

Fixable

Every issue has a known, standard fix. None require re-architecture.

What's already working well

Not every finding is bad news. Three controls were tested and confirmed as effective — they should stay in place and be re-verified annually.



Public-facing app cannot reach staff logins

The customer-facing website is walled off from the corporate directory that holds staff credentials. A breach of the website would not automatically give an attacker staff access.



Payment services cannot reach staff logins

The payment-processing services are similarly walled off from the corporate directory. Compromise of a payment service would not automatically reach staff accounts.



Secure messaging between staff systems

Communication between staff computers and the directory server is cryptographically signed — protecting against a common class of network attacks.

The four findings that matter most

CRITICAL

Customer data was downloadable by anyone

A file with names, emails, national IDs, card numbers, security codes and wallet PINs sat on the public website with no password. In a live environment this would be a reportable data breach.

1

CRITICAL

The card system is open to the public

The system that lists customer cards has no login. Anyone able to reach it could pull the full card list — names, numbers, security codes.

2

CRITICAL

Admin access via a login trick

Someone with basic skills can sign in as an administrator by manipulating the login form. Once in, they have full control of the customer app.

3

CRITICAL

The customer database is remotely accessible with total control

The main customer database has a top-level admin account that accepts logins from anywhere on the payment network, with unrestricted power to read, change, or delete every record.

4

The six high-risk findings

PayNova assessment · findings rated High

HIGH

1

Excessive DMZ-to-payment network reachability

Internet-facing servers can reach the internal payment network far more freely than they need to. One compromised public server becomes a direct path into payment systems.

HIGH

2

Customer backup exposed without login

A customer backup holding full card numbers, security codes and PINs could be downloaded by anyone. In a live environment this would be a reportable card data breach.

HIGH

3

Debug settings and token-signing secret disclosed

The app reveals its debug configuration, including the secret key that signs login tokens. With that key, an attacker can forge a valid session for any user, admins included.

HIGH

4

Sensitive customer PII stored in cleartext

Customer personal details are stored without encryption. Anyone who gains access to the database can read them as plain text.

HIGH

5

Excessive database privileges on paynova_app

The account the application uses to reach the database holds far more rights than it needs. If the app is compromised, the attacker inherits that power over the data.

HIGH

6

Weak password hashing (MD5)

User passwords are protected with MD5, an outdated method that free tools crack quickly. A stolen password table would expose most real passwords within hours.

The path from here to a defensible position

P0

Now — 7 days

- Take exposed data offline (backup file + card API)
- Remove database super-admin remote access
- Remove card security codes from database
- Regulatory & customer notifications; card reissuance

P1

1 — 30 days

- Close network path web tier → payment tier
- Fix admin authorisation checks in the app
- Fix weak staff-directory password policy
- Encrypt customer personal data at rest
- Least-privilege for the application database account

P2

1 — 3 months

- Move payment APIs to production-grade platform
- Fix cross-origin policy on customer website
- Fix search-page scripting flaw
- Disable staff-directory anonymous share listing
- Migrate customer passwords off legacy MD5 hashing

P3

3 — 6 months

- Restrict staff-directory info disclosure
- Remove info-leak paths (robots file, headers)
- Restrict database at the network layer
- Complete third-party risk register

Every technical fix has a known playbook. None of the actions require re-architecture, new platforms, or new vendors.

What's at stake if these exposures reach production

Customer trust

A single visible breach of payment card details is a threshold event for customer confidence in a fintech. Recovery typically takes 12–24 months.

Regulatory action

Notification obligations, potential fines from NDPC (Nigeria), ICO (UK) and EU supervisory authorities, and CBN cybersecurity reporting.

Card scheme sanctions

Storing card security codes is prohibited by the card industry. Discovery would trigger scheme investigation and possible transaction-processing sanctions.

Direct financial cost

Card reissuance, customer notification, forensic investigation, legal and PR support. Card scheme fines can be significant per exposed record.

Who we would need to notify, and how quickly

Regulator	Applies when	Notification window
Nigeria Data Protection Commission (NDPC)	A Nigerian customer's personal data is affected	Without undue delay
UK Information Commissioner's Office (ICO)	A UK customer's personal data is affected	Within 72 hours
EU supervisory authorities	An EU customer's personal data is affected	Within 72 hours
Card scheme (Visa, Mastercard, Verve)	Card data is exposed or suspected exposed	Typically within 24 hours
Central Bank of Nigeria (CBN)	Material cybersecurity incident affecting a licensed institution	Per current CBN circular
Affected customers	The exposure is likely to cause them real harm	Without undue delay

Reading this: our customer base includes Nigerian, UK, and German data subjects – so any one of the confirmed data exposures would engage all three privacy regimes plus the card scheme.

Immediate actions — next 7 days

What	Why	Owner
Take the exposed customer file offline	Stop the loss; preserve logs for investigation	Website team
Take the open card-listing page offline	Stop the loss on customer card data	Payment team
Remove the database super-admin remote account	Total database compromise is one credential away today	Database team
Remove card security codes from the database	Storing them is prohibited by the card industry	Database team
Rotate the key that lets the app trust customer logins	A copy may have been captured; force everything to re-issue	Payment team
Patch the admin login trick	Close the door before it is used against a real account	Website team
Notify affected customers and regulators (if real data involved)	Legal obligation — 72-hour window in some jurisdictions	Data Protection Officer
Force new cards and PIN resets for affected customers	Contain the potential fraud impact	Card operations

What we need from you today

1

Approve the emergency response plan

Take the exposed data offline and open the incident-response process. This work starts immediately.

2

Endorse the 6-month roadmap

Confirm the P0–P3 prioritisation so the teams can begin planning against it this week.

3

Nominate a Data Protection Officer

The role is required by NDPA for organisations of our scale; it also owns regulator notifications.

4

Approve budget for the top-three fixes

The critical items have a small, defined cost envelope. Approval today saves days on the P0 track.

Questions

We're here to walk through any of this in more detail.



Guardians of data and digital innovations